



UNIVERSIDAD TECNOLÓGICA DE TEHUACÁN

Nombre Del Alumno:
Alejandro Contreras Martinez

Docente:
José Miguel Carrera Pacheco

**Login seguro, accesible y
controlado por teclado**

**ING EN DESARROLLO
DE SOFTWARE
MULTIPLATAFORMA**

- **¿Cómo debe comportarse un formulario accesible?**

Un formulario accesible permite que cualquier persona pueda utilizarlo, incluyendo usuarios con discapacidades visuales, motoras o cognitivas. Debe cumplir con las recomendaciones de accesibilidad web como las definidas por la World Wide Web Consortium (W3C) y su estándar Web Content Accessibility Guidelines.

- **¿Qué errores comunes existen en formularios de login?**

Algunos errores comunes de los formularios

- **No especificar dónde hay un error de registro**

Es común que los usuarios cometan errores durante el llenado del formulario de registro. Es importante que cuando esto suceda, puedan distinguir cuáles son los campos incorrectos para poder arreglarlos.

Uno de los errores comunes en formularios online es no señalar estos puntos para que el usuario pueda corregirlos rápidamente y continuar con el registro en el menor tiempo posible. De esta forma evitarás que abandonen el formulario.

- **No ofrecer la ayuda básica**

La ayuda básica puede parecer innecesaria en muchas ocasiones. Sin embargo, para muchos usuarios puede servir como guía para poder terminar el registro de información.

Agregar a opción de ayuda básica permite que los usuarios tengan un ejemplo sobre cómo deben de rellenar los campos del formulario y que, de esta forma, puedan completarlo fácilmente.

- **Falta de claridad en las etiquetas y mensajes**

Un formulario debe ser claro. No puede insinuar; debe explicar de forma directa lo que quiere del usuario. Etiquetas confusas, textos demasiado técnicos o instrucciones colocadas en lugares poco visibles.

- **¿Cómo se manejan sesiones de forma segura?**

Existen diferentes manejos de sesiones como lo son

- **Sesiones basadas en cookies**

Las cookies son un enfoque común para la gestión de sesiones en aplicaciones web. Son pequeños fragmentos de datos generados por un servidor que están en el dispositivo del usuario, normalmente en el navegador web. Las cookies rastrean

el comportamiento del usuario y pueden usarse para señalar a un sistema centralizado que algo no va bien, o pueden configurarse para forzar la terminación de una sesión o activar automáticamente la reautenticación.

- **Sesiones basadas en tokens**

Los tokens son pequeños fragmentos textuales de datos. Este método aprovecha tokens ID, tokens de acceso y tokens de actualización para iniciar y controlar el acceso de usuarios en múltiples dispositivos y sistemas. El cliente incluye este token (normalmente en formato JWT) en la cabecera de autorización de las solicitudes HTTP para autenticar y gestionar sesiones. La gestión de sesiones basada en tokens es especialmente popular en APIs RESTful y Aplicaciones de Página Única (SPA), ya que soporta autenticación sin estado.

Un beneficio importante de este enfoque es que los límites de tiempo y otras características de seguridad pueden integrarse directamente en los propios tokens. Y, dado que los tokens son relativamente ligeros, pueden escalar junto a cualquier pila tecnológica. También proporcionan seguridad en una amplia variedad de entornos de hardware, software y red, con pocas limitaciones en cuanto a compatibilidad.

La autenticación basada en tokens es una de las mejores formas de garantizar una gestión segura de las sesiones.

• **¿Cómo se muestran errores de autenticación sin filtrar información sensible?**

Este es un punto crítico de seguridad para evitar la enumeración de usuarios (que un atacante sepa qué correos están registrados).

- Mensajes genéricos: En lugar de decir "La contraseña es incorrecta" o "El usuario no existe", utiliza: "El correo electrónico o la contraseña son incorrectos".
- Tiempos de respuesta constantes: A veces, los sistemas tardan más en responder si el usuario existe que si no existe.
- No confirmar existencia en registros: Si tienes un formulario de "Olvidé mi contraseña", el mensaje debe ser: "Si el correo ingresado está en nuestra base de datos, recibirás un enlace para restablecerlo", en lugar de confirmar si se envió o no.